UNIVERSIDAD CAECE

Cámara Argentina de Comercio y Servicios

LICENCIATURA EN CIENCIA DE DATOS

SEGURIDAD INFORMÁTICA

GUIA DE LA UNIDAD I

Contenidista: Germán Ariel Paradisi

INDICE – Guía Nro. 1

1. RIESGOS, AMENAZAS VULNERABILIDADES.....5
1.1 Tipos de amenazas..... 6
1.2 Vulnerabilidades.....7
2. LA SEGURIDAD EN TÉRMINOS GENERALES..... 8
3. CONCEPTO DE SEGURIDAD INFORMÁTICA.....8
4. CONTROLES PREVENTIVOS.....10
5. CONTROLES CORRECTIVOS.....10
6. CONTROLES DETECTIVOS..... 11
7. LOS PILARES DE LA SEGURIDAD.....12
7.1 Integridad..... 13
7.2 Disponibilidad.....13
7.3 Confidencialidad.....14
8. PRINCIPIO DE MÍNIMOS PRIVILEGIOS..... 14
9. SUPERFICIE DE ATAQUE..... 15

MAPA DE LA GUIA 1: Fundamentos de la Seguridad de la Información

OBJETIVOS

En esta Unidad esperamos que el estudiante pueda

- Reconocer y clasificar amenazas, vulnerabilidades y ataques en entornos digitales.
- Comprender los principios básicos de seguridad informática y sus componentes.
- Analizar y aplicar los pilares fundamentales de seguridad informática en la protección de sistemas y datos.

CONTENIDOS:

1. **RIESGOS, AMENAZAS VULNERABILIDADES**
2. **CONCEPTO DE SEGURIDAD INFORMÁTICA**
3. **CONTROLES**
   - 3.1. Preventivos
   - 3.2. Correctivos
   - 3.3. Detectivos
4. **LOS PILARES DE LA SEGURIDAD**
   - 4.1. Integridad
   - 4.2. Disponibilidad
   - 4.3. Confidencialidad

PALABRAS CLAVE

Amenazas informáticas – Controles de seguridad – Integridad – Disponibilidad – Confidencialidad – Superficie de ataque – Vulnerabilidades Informáticas – Seguridad de la información – Seguridad informática.

BIBLIOGRAFÍA Y MATERIALES DE REFERENCIA OBLIGATORIOS

Grubb, S. (2021). How Cybersecurity Really Works_ A Hands-On Guide for Total Beginners. Editorial No Starch Press

Romero, M; Figueroa, G; Vera, D; Álava, J; Parrales, G; Álava, C; Murilo, Á; Castillo,M. (2018). Introducción a la Seguridad Informática y el Análisis de Vulnerabilidades. Editorial Área de Innovación y Desarrollo,S.L.

BIBLIOGRAFÍA Y MATERIALES DE REFERENCIA OPTATIVOS

Diogenes, Y; Ozkaya, E. (2018). Ciberseguridad: Estrategias de ataque y defensa. Editorial Packt.

1. RIESGOS, AMENAZAS VULNERABILIDADES

Cuando se plantea mejorar la seguridad de una empresa es necesario tener en cuenta varios factores que se muestra a continuación:

- Recursos
- Amenazas
- Vulnerabilidades
- Riesgos

Los **recursos** se refieren a los activos tanto **tangibles** como **intangibles** utilizados para llevar a cabo las **operaciones de la empresa**. Entre los activos intangibles se encuentran la información, como las bases de datos de clientes, proveedores, manuales de producción, investigaciones y patentes. Por otro lado, los activos tangibles incluyen los recursos físicos como servidores, equipos de red, computadoras, teléfonos inteligentes, vehículos, bienes inmuebles, entre otros.

El **riesgo** se define como la **posibilidad de que ocurra un evento adverso que cause un daño** a los recursos, tanto tangibles como intangibles, y, por ende, obstaculice el desarrollo de las actividades profesionales.

Las **amenazas** representan los **eventos que tienen el potencial de perjudicar los procesos o recursos**, mientras que las **vulnerabilidades** son las **debilidades en los sistemas de seguridad o en los propios procedimientos** que el usuario emplea para llevar a cabo sus actividades. Estas vulnerabilidades podrían permitir que una amenaza tenga éxito en generar un problema.

Por otro lado, la función principal de un **responsable de seguridad** es llevar a cabo una **evaluación de riesgos que identifique las vulnerabilidades y amenazas**. A partir de esta evaluación, se determina el grado de riesgo al que están expuestas las actividades y recursos. Es crucial considerar **el riesgo como la probabilidad de que una amenaza específica explote una vulnerabilidad particular**.

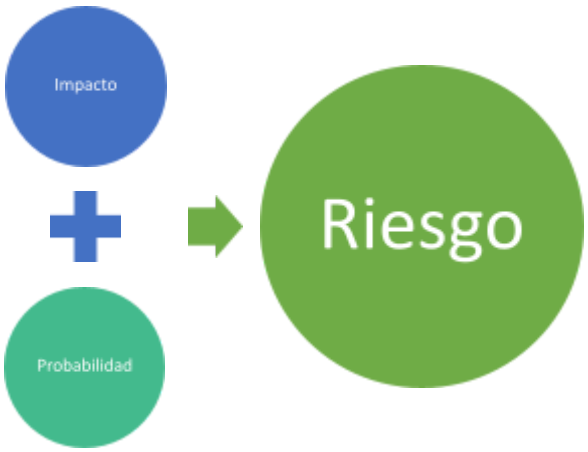

Figura 1. Componentes del riesgo. Elaboración propia

Además, en un **proceso de evaluación de riesgos básico**, podría asignarse un valor numérico al impacto de una vulnerabilidad y otro valor la probabilidad de ocurrencia de una amenaza. A continuación, se incluye una tabla que ilustra un ejemplo de evaluación de riesgos simple.

Amenaza	**Impacto**	**Probabilidad**	**Riesgo**
Robo de credenciales de un sistema biométrico	3	0	0
Infección con un código malicioso	2	3	6
Pérdida de suministro eléctrico	3	1	3

Figura 2. Evaluación de riesgos. Elaboración propia

En la tabla mencionada, las amenazas que no conllevan ningún daño se valorarán con un impacto de 0, mientras que aquellas que ocasionan un gran daño se asignaría un valor de impacto de 3. Del mismo modo, la probabilidad podría ser nula, baja, media o alta, lo que permitiría asignar valores de probabilidad del 0 al 3. Al multiplicar ambos valores, se obtendría el nivel de riesgo, lo que facilita la clasificación de los distintos riesgos a los que se enfrenta y permitiría tomar medidas en consecuencia, dando prioridad a los más graves. Por ejemplo, si existe una amenaza de ataques mediante el robo de credenciales para acceder a un recurso cifrado, el impacto de perder esa información sería alto. Sin embargo, si se cuenta con un sistema de autenticación biométrica, las probabilidades de que esa amenaza sea explotable son prácticamente nulas, por lo que el riesgo sería mínimo para esa amenaza.

1.1 Tipos de amenazas

En el ámbito de la seguridad informática, es crucial considerar una amplia gama de amenazas tanto naturales como deliberadas al evaluar los riesgos para una organización. Las amenazas naturales, como desastres naturales o errores humanos involuntarios, pueden desencadenar

situaciones adversas impredecibles. Por ejemplo, un empleado podría eliminar accidentalmente información importante de un servidor o enviar por error un correo electrónico con datos confidenciales a un destinatario equivocado. Además, el hardware de los recursos informáticos de la empresa está expuesto a daños por diversas causas, como el uso constante, inundaciones o fallos eléctricos, lo que puede afectar la disponibilidad y la integridad de los datos.

Por otro lado, las amenazas deliberadas representan un riesgo significativo y pueden provenir tanto de agentes internos como externos de la organización. Los agentes internos, como empleados descontentos o ex empleados con credenciales de acceso no revocadas, pueden representar una amenaza considerable debido a su familiaridad con los sistemas y datos internos. Por otro lado, los agentes externos pueden incluir competidores desleales, activistas, terroristas y cibercriminales, entre otros, que pueden llevar a cabo ataques maliciosos con el objetivo de causar daño, robar información confidencial o interrumpir las operaciones comerciales.

Al comprender la naturaleza y el alcance de estas diversas amenazas, las organizaciones pueden tomar medidas proactivas para mitigar los riesgos y proteger sus activos críticos de manera efectiva. Esto puede incluir la implementación de medidas de seguridad física y lógica, la capacitación del personal en prácticas seguras, la implementación de políticas de acceso y control de datos, y la adopción de tecnologías avanzadas de detección y respuesta ante incidentes. En última instancia, la seguridad informática debe ser una prioridad estratégica para cualquier organización que busque proteger su información sensible y mantener la continuidad de sus operaciones comerciales.

1.2 Vulnerabilidades

En el ámbito de la seguridad informática, es esencial comprender el concepto de vulnerabilidad y su impacto en la integridad y seguridad de los sistemas. Las vulnerabilidades son fundamentalmente **fallos de diseño en los procedimientos o recursos** que pueden ser explotados por amenazas para comprometer la seguridad de un sistema. Es importante destacar que las vulnerabilidades no se crean intencionalmente; más bien, surgen como **resultado de errores en el diseño**, **la implementación** o **la configuración de sistemas y procedimientos**.

Cuando hablamos de vulnerabilidades en el contexto de los recursos informáticos, nos referimos a defectos en el diseño, **la actualización o la configuración de un sistema** que permiten a agentes externos acceder a recursos o información sin los permisos adecuados. Por ejemplo, un sistema desactualizado o mal configurado puede dejar una puerta abierta para que un atacante acceda de manera no autorizada a datos sensibles o sistemas críticos.

Para identificar y mitigar estas vulnerabilidades, es crucial contar con fuentes de información confiables donde se puedan encontrar detalles sobre vulnerabilidades conocidas y formas de remediarlas. Existen diversas fuentes, como bases de datos de vulnerabilidades, boletines de seguridad, informes de investigaciones de seguridad y comunidades en línea de profesionales

de la seguridad informática, que proporcionan información valiosa sobre vulnerabilidades específicas y las mejores prácticas para abordarlas.

2. LA SEGURIDAD EN TÉRMINOS GENERALES

Cuando nos referimos a la **seguridad informática**, es importante tener claros los fundamentos que sustentan esta disciplina. Uno de estos fundamentos es el concepto mismo de seguridad, que implica un estado de bienestar caracterizado por la **ausencia de riesgos**, gracias a la confianza depositada en un individuo o un sistema. Desde una perspectiva disciplinaria, la seguridad puede entenderse como un campo interdisciplinario dedicado a **evaluar y gestionar los riesgos** que afectan a personas, animales, el medio ambiente o cualquier otro activo. En esencia, se trata de un **enfoque integral que busca identificar y mitigar los peligros potenciales** para preservar la integridad y el funcionamiento adecuado de los sistemas y recursos involucrados.

Existen países en donde la seguridad es un tema nacional, aunque depende del tipo de seguridad ya que existen muchos tipos (la seguridad ambiental, la seguridad económica, la seguridad sanitaria). Cabe agregar, además, que cuando se hace un análisis de la palabra seguridad en la mayoría de los países, se hace referencia a la seguridad de las personas, por ejemplo, evitar el estado de riesgo de un robo, de un daño físico o de un bien material.

La seguridad siempre busca la gestión de riesgos, es decir, que se tenga siempre una forma de **evitarlo o prevenirlo** y que se puedan realizar ciertas acciones para evitar esas situaciones de la mejor forma.

Se definió que la seguridad podría ser catalogada como la ausencia de riesgo, la definición de este término involucra cuatro acciones que siempre están inmersas en cualquier asunto de seguridad como son:

- Prevención del riesgo
- Transferir el riesgo
- Mitigar el riesgo
- Aceptar el riesgo

Así que, cuando se está buscando hacer algo más seguro, es necesario considerar estas acciones sin importar el área; asimismo, se aplica a cualquier intento de tener mejor o mayor seguridad en cualquier tema que se requiera.

3. CONCEPTO DE SEGURIDAD INFORMÁTICA

Es importante destacar que, en ocasiones, se tiende a confundir algunos términos fundamentales: **seguridad informática** y **seguridad de la información**. Aunque los dos suenan similares, existen diferencias clave que los distinguen.

La **seguridad informática** se centra en la protección del entorno informático en sí mismo; abarca los **procesos, técnicas y métodos destinados a procesar, almacenar y transmitir información**. Por otro lado, la **seguridad de la información no se limita únicamente al entorno informático, sino que abarca todo aquello que pueda contener datos sensibles**.

En términos generales, se busca garantizar la protección de la **confidencialidad**, **integridad** y **disponibilidad** de la información. Esto incluye la implementación de controles y medidas de seguridad para prevenir el acceso no autorizado, la alteración o la destrucción de la información.

La **seguridad informática** se encarga de establecer y diseñar **normas**, **procedimientos**, **métodos y técnicas** con el objetivo de garantizar la seguridad, confiabilidad y disponibilidad de un sistema de información.

La principal función de la seguridad informática es **minimizar los riesgos asociados**. Estos riesgos pueden originarse en diversas fuentes, como la entrada de datos, los medios de transporte de la información, el hardware utilizado para la transmisión y recepción, los propios usuarios e incluso los protocolos implementados. No obstante, el **objetivo primordial siempre es reducir al máximo los riesgos para lograr una mayor seguridad y fiabilidad en los sistemas informáticos**.

Lo que debe contemplar la seguridad se puede clasificar en tres partes:

- Los usuarios
- La información
- La infraestructura

Los **usuarios** son considerados como el eslabón más débil de la cadena, ya que es imposible controlar a las personas; un usuario puede cometer un error y olvidar algo o tener un accidente y este suceso puede echar a perder el trabajo de mucho tiempo; en muchos casos el sistema y la información deben de protegerse del mismo usuario.

La **información** se considera como el oro de la seguridad informática ya que es lo que se desea proteger, es lo que tiene que estar a salvo; se dice que es el principal activo.

Por último, la **infraestructura** puede ser uno de los medios más controlados, pero eso no implica que corra menos riesgos, siempre dependerá de los procesos que se manejan. Se deben de considerar problemas complejos, como los de un acceso no permitido, robo de identidad, hasta los daños más comunes, por ejemplo, robo del equipo, inundaciones, incendios o cualquier otro desastre natural que puede tener el material físico del sistema de la organización.

En conclusión, la seguridad informática puede definirse como el conjunto de métodos y de herramientas para proteger el principal activo de una organización como la **información o los sistemas** ante una eventual amenaza que se pueda suscitar.

4. CONTROLES PREVENTIVOS

Los **controles preventivos** en seguridad informática suelen ser pasados por alto con frecuencia. Desde una perspectiva administrativa, estos mecanismos son a menudo percibidos como costos adicionales que podrían evitarse. Sin embargo, es importante comprender que estos controles constituyen una serie de **medidas preventivas que incluyen revisiones periódicas, ajustes o mejoras** en diversos aspectos, ya sean de hardware, software u otros elementos relacionados con los sistemas y procesos de una empresa. Es crucial destacar que estas revisiones deben adaptarse a los procesos específicos de cada organización, cada uno con sus propios procedimientos establecidos.

Los controles preventivos **son de naturaleza a largo plazo** y, por lo tanto, a menudo se perciben como una inversión de tiempo y recursos que no proporciona beneficios inmediatos. No obstante, es importante reconocer que la implementación adecuada de estos mecanismos puede **ayudar a prevenir una amplia gama de ataques informáticos** o, al menos, **mitigar su impacto**. La principal barrera que enfrentan las empresas al intentar aplicar estos mecanismos radica en la aceptación y el compromiso de todas las partes involucradas. Es fundamental transmitir la idea de que estos mecanismos no son una carga adicional, sino una parte integral de los procesos y una medida necesaria para garantizar la seguridad y eficiencia en la organización.

Algunos ejemplos de controles o tecnologías que se tienen en el mecanismo preventivo son:

- Actualización de sistemas
- Soluciones de detección de códigos maliciosos
- Firewall
- Contraseñas

Estos son sólo algunos ejemplos, pero la organización puede personalizar lo que quiere considerar en los mecanismos preventivos.

5. CONTROLES CORRECTIVOS

Los controles correctivos presentan una marcada diferencia temporal en comparación con los controles preventivos; **se implementan después de que ocurra un incidente**, con el propósito principal de **corregir el impacto**. Entre las características distintivas de los controles correctivos, suele destacarse su **alto costo**, dado que se aplican una vez que el problema ya ha ocurrido y no se puede tolerar su prolongación en el tiempo. En consecuencia, contratar expertos para resolver el problema o destinar recursos adicionales al equipo de trabajo resulta costoso. En muchos casos, las organizaciones se ven obligadas a pagar por servicios de solución proporcionados por terceros, adquirir soluciones comerciales o comprar software y parches de actualización para resolver el problema.

Otro aspecto relevante de los controles correctivos es la limitación temporal; **el tiempo se convierte en un recurso extremadamente valioso y escaso en estas circunstancias**. Aunque una empresa o persona pueda disponer de recursos financieros para abordar la situación, el tiempo disponible suele ser insuficiente. Es importante tener en cuenta que, en situaciones de emergencia, el tiempo es un factor crítico que debe gestionarse de manera eficaz para minimizar el impacto negativo del incidente.

6. CONTROLES DETECTIVOS

Los controles de detección son de los **más complejos** y requieren un alto grado de conocimientos técnicos, dependiendo del área específica que se esté abordando. Por ejemplo, en la seguridad de plataformas en línea, especialmente en sistemas de bases de datos o tecnologías de gestión de contenidos, esto variará según el sistema, la aplicación o el entorno en el que estén operando.

Los controles de detección **parten del supuesto de que un atacante podría comprometer la seguridad** y haber realizado una intrusión total o parcial en un recurso determinado. Por lo tanto, al implementar estos controles, es necesario trabajar bajo la premisa de que lo que se descubra puede ser lo peor, estando preparados para enfrentar las situaciones más adversas.

Estos controles de detección tienen dos objetivos principales:

- Identificar el punto exacto del ataque para poder tomar medidas correctivas y recuperarse de la intrusión. Sin embargo, esto no siempre es factible, ya que depende de la naturaleza y la gravedad del problema.
- Detectar actividades sospechosas y comprender lo sucedido. Incluso si no es posible determinar el punto exacto del ataque, es fundamental conocer qué ocurrió para poder tomar medidas adecuadas.

Idealmente, se lograría cumplir ambos objetivos. No obstante, en la práctica, esto no siempre es posible, por lo que es necesario adaptarse a la situación y tomar las medidas necesarias en función de las circunstancias.

Uno de los conceptos fundamentales en estos controles es el de intrusión, que se define como una serie de acciones realizadas de manera deshonesta, con el objetivo generalmente de obtener acceso no autorizado. Dentro de los controles de detección, uno de los términos más conocidos en seguridad informática es el de detección de intrusiones, que consiste en el proceso de identificación y respuesta ante actividades ilícitas observadas en los recursos de una red, sistema, plataforma o empresa.

7. LOS PILARES DE LA SEGURIDAD

En el complejo entorno digital actual, la seguridad de la información se erige como un pilar fundamental para la operatividad y el éxito de cualquier entidad, ya sea una empresa, una organización gubernamental o un individuo. Esta seguridad se sustenta en tres pilares esenciales que garantizan la protección y el aprovechamiento óptimo de la información: **confidencialidad, integridad y disponibilidad**.

Estos pilares, intrínsecamente ligados entre sí, constituyen **la base sobre la cual se construyen las estrategias y medidas de seguridad** que permiten minimizar los riesgos y maximizar el rendimiento en el uso de la información.

Figura 3. Pilares de la seguridad de la información. Elaboración propia

La seguridad está fundamentada por 3 pilares, aunque cabe destacar que pueden existir otros elementos complementarios. La fortaleza de cada uno de estos pilares es crucial, ya que cualquier debilidad en alguno de ellos puede comprometer tanto la seguridad como la usabilidad del sistema. En ausencia de alguno de estos pilares, la organización queda expuesta a una serie de riesgos y vulnerabilidades que pueden ser explotados por posibles ataques.

Es esencial comprender la importancia intrínseca de la información en el entorno actual. Cuando la información cae en manos indebidas, su valor se desvanece rápidamente, ya que puede implicar la pérdida de privacidad, capacidad de maniobra e incluso dañar la reputación de la organización. Además, **la exposición de información confidencial a cibercriminales y otras amenazas potenciales representa un riesgo significativo para cualquier proyecto o iniciativa**. Es por ello que la protección de la información se convierte en una prioridad absoluta en el ámbito de la seguridad informática.

7.1 Integridad

La integridad de la información es un pilar fundamental en la seguridad informática, ya que **garantiza que los datos no se pierdan ni se vean comprometidos de manera intencional o accidental**. Trabajar con información incorrecta puede ser igual de perjudicial que perderla por completo, ya que la manipulación sutil de los datos puede desencadenar una serie de errores en cascada, conduciendo a decisiones equivocadas. Para asegurar la integridad de la información, es crucial considerar diversas medidas:

1. Monitoreo del tráfico de red para detectar posibles intrusiones y actividades sospechosas que puedan comprometer la integridad de los datos.
2. Implementación de políticas de auditoría en los sistemas para registrar todas las acciones realizadas, incluyendo quién accede a qué información, cuándo y con qué propósito.
3. Establecimiento de sistemas de control de cambios que permitan verificar la integridad de los archivos de información almacenados, mediante la comparación de resúmenes o firmas digitales para detectar cualquier modificación no autorizada.
4. Uso de copias de seguridad como medida de contingencia, permitiendo restaurar la información en caso de manipulación o pérdida, garantizando su recuperación en su estado original.

Estas estrategias combinadas contribuyen a preservar la integridad de la información y a protegerla contra posibles alteraciones o pérdidas no deseadas.

7.2 Disponibilidad

La disponibilidad es un elemento crucial en la seguridad de la información, ya que **asegura que los datos estén accesibles cuando se necesiten**. No basta con que la información sea accesible solo para el usuario autorizado y sea incorruptible; también debe estar disponible de manera rápida y eficiente. La falta de disponibilidad puede hacer que la información pierda su utilidad y valor. Por ejemplo, si una dirección de correo electrónico es utilizada para enviar spam y es añadida a listas negras, los correos legítimos pueden no llegar a sus destinatarios.

Para garantizar la disponibilidad de la información, se implementan diversas políticas de control, tales como:

- Acuerdos de nivel de servicio (SLA) que establecen los tiempos de disponibilidad y respuesta ante incidentes.
- Uso de balanceadores de carga de tráfico para mitigar los impactos de ataques DDoS y mantener la operatividad de los servicios.
- Realización de copias de seguridad para la restauración de datos en caso de pérdida o corrupción.

- Disponibilidad de recursos alternativos en caso de fallos en los sistemas primarios.

Además, es fundamental establecer normas y procedimientos para el uso adecuado de los sistemas de información frente a posibles amenazas. Esto implica la elaboración de políticas claras, la definición de acciones que deben tomar las personas involucradas y la delimitación del perímetro de afectación en caso de incidentes. De esta manera, se garantiza que la información esté disponible cuando sea requerida, manteniendo su integridad y utilidad para los usuarios autorizados.

7.3 Confidencialidad

La confidencialidad garantiza que **solo las personas autorizadas accedan a los datos correspondientes**. Este principio asegura que cada sistema automático o individuo pueda utilizar los recursos necesarios para realizar sus tareas sin comprometer la confidencialidad de la información. Para lograrlo, se recurre a tres recursos principales:

- **Autenticación de usuarios:** Este proceso identifica y verifica la identidad de quienes intentan acceder a la información, asegurando que sean quienes dicen ser.
- **Gestión de privilegios:** Permite que los usuarios accedan al sistema y operen únicamente con la información autorizada para ellos, y de la manera en que se les ha permitido. Por ejemplo, se gestionan permisos de lectura o escritura según el usuario y sus funciones.
- **Cifrado de información:** Esta técnica, también conocida como encriptación, protege la información haciendo que sea ilegible para quienes no están autorizados. La información se transforma en un formato no legible y solo puede ser decodificada mediante un sistema de contraseñas. El cifrado se aplica tanto a la información en tránsito como a la almacenada.

Es importante aplicar los principios de confidencialidad no solo para proteger la información valiosa de la organización, sino también para todos los datos de los que se sea responsable. Además, la confidencialidad puede estar respaldada por la legislación de protección de datos personales. Por ejemplo, las filtraciones de información sufridas por entidades bancarias, grandes empresas y gobiernos pueden exponer públicamente actividades sensibles, lo que constituye una violación de la confidencialidad.

8. PRINCIPIO DE MÍNIMOS PRIVILEGIOS

El Principio de Mínimos Privilegios es fundamental en la seguridad de la información, ya que establece que **cada usuario o sistema debe tener acceso únicamente a los recursos necesarios para llevar a cabo sus funciones**, sin privilegios innecesarios ni permanentes. Esto implica definir claramente qué

recursos puede acceder cada individuo o herramienta, así como qué acciones pueden realizar sobre esos recursos, lo que se conoce como privilegios y permisos.

Los privilegios son los permisos que un usuario o sistema tiene para actuar sobre otros recursos. Un ejemplo común de sistemas de privilegios son las cuentas de usuario en sistemas operativos como Windows, Mac o Linux. Estas cuentas se dividen principalmente en usuarios normales y administradores, con la posibilidad de crear grupos con características específicas. Los usuarios normales pueden utilizar las herramientas instaladas en la computadora y acceder a la información de su directorio de usuario, mientras que los administradores tienen privilegios adicionales para acceder a otras áreas del sistema, instalar o eliminar software y configurar parámetros del sistema operativo.

El principio de mínimos privilegios establece que cada usuario debe disponer solo de los **privilegios mínimos necesarios para realizar una tarea específica, durante el tiempo imprescindible y con un alcance limitado a lo que exija la tarea en cuestión**. Por ejemplo, al trabajar con una computadora, se debería utilizar un usuario normal para operaciones cotidianas como navegar por internet o gestionar el correo electrónico, reservando el usuario con privilegios de administrador únicamente para realizar tareas que requieran cambios en la configuración del sistema o la instalación de software.

Este enfoque **minimiza el riesgo de amenazas** como códigos maliciosos, espionaje o corrupción de archivos del sistema, al restringir el acceso a recursos y privilegios sólo a aquellos necesarios para llevar a cabo las funciones específicas de cada usuario o sistema.

9. SUPERFICIE DE ATAQUE

La superficie de ataque de una infraestructura IT se refiere al **conjunto de elementos que pueden ser vulnerables y susceptibles de ser explotados por incidentes naturales o ataques deliberados**. Este concepto abarca diversos componentes, incluyendo dispositivos de red como routers, switches y firewalls, así como computadoras, servidores y sistemas de almacenamiento en red.

Además, también se incluyen los sistemas operativos, aplicaciones y firmware utilizados en estos equipos.

Es importante destacar que las personas que interactúan con y administran esta tecnología también forman parte de la superficie de ataque, ya que pueden introducir sus propias vulnerabilidades. En resumen, **la superficie de ataque representa todos los puntos potenciales de vulnerabilidad** dentro de una infraestructura IT, lo que subraya la importancia de implementar medidas de seguridad adecuadas para mitigar los riesgos.

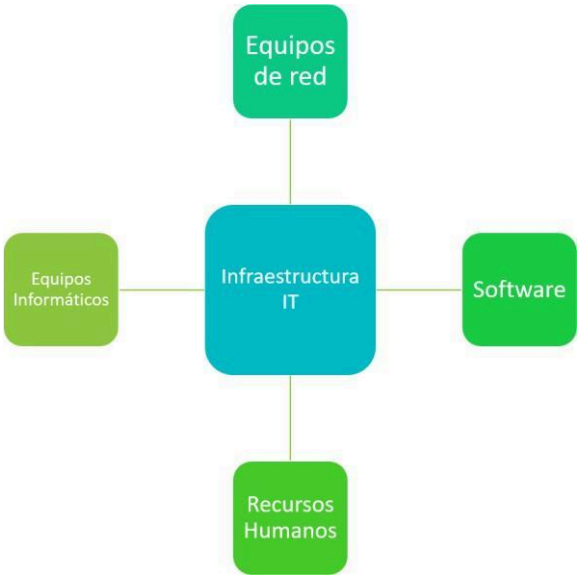

Figura 4. Componentes de la superficie de ataque. Elaboración propia

A medida que aumenta la superficie de ataque, es decir, cuantos más elementos estén expuestos, mayores son las probabilidades de que existan vulnerabilidades disponibles para un ataque. Por lo tanto, **minimizar esta superficie implica reducir los riesgos potenciales** y, además, puede ayudar a disminuir la magnitud de los riesgos que no se pueden evitar.

Al estudiar las diferentes superficies de ataque, se identifican dos formas de ataque: pasiva y activa.

El **ataque pasivo** implica **monitorear al sujeto atacado sin afectar directamente la infraestructura**. Este tipo de ataque no es invasivo, pero permite observar lo que la infraestructura puede almacenar o transmitir, incluso información que sea de dominio público. Para llevar a cabo este tipo de ataques, se emplean técnicas de monitorización de tráfico en busca de documentos, contraseñas o fuentes abiertas de información, conocidas como OSINT.

Los ataques pasivos **están diseñados exclusivamente para obtener información** que puede ser suficiente en sí misma o para ser utilizada en ataques posteriores. Por esta razón, identificar un ataque pasivo puede alertar al usuario sobre la posibilidad de un ataque activo.

En contraste, los **ataques activos** se caracterizan por **acciones directas que buscan penetrar la infraestructura** y establecerse dentro de ella de manera permanente. Los objetivos de estos ataques suelen ser sabotajes, robo de información o despliegue de malware con fines de espionaje o secuestro de equipos para otros ataques.

Se pueden examinar diversas superficies para identificar posibles amenazas y vulnerabilidades, como:

Software: Esta superficie comprende aplicaciones, servicios, ejecutables, páginas web y otros servicios como NFTP, TELNET, entre otros. Las vulnerabilidades en el software son fallos en la programación o compilación de programas que pueden resultar en mal funcionamiento, acceso no autorizado a información, fallos del sistema, etc. Para reducir esta superficie de ataque, es fundamental minimizar el software instalado, mantenerlo actualizado con los parches de seguridad y configurarlo con el principio de los mínimos privilegios en mente. También se debe evitar el uso de software pirata o de fuentes no confiables, y realizar análisis periódicos en bases de datos públicas de vulnerabilidades para identificar posibles riesgos.

Hardware: Esta es la segunda superficie de ataque más comúnmente considerada. Las amenazas naturales como el envejecimiento de equipos o desastres como robos, incendios o inundaciones pueden afectar esta área. Los ataques al hardware pueden ocurrir a través de la red o afectar al medio físico de transmisión. Por ejemplo, los perturbadores de señal pueden interrumpir comunicaciones inalámbricas, anulando sistemas de comunicación críticos. Para minimizar esta superficie de ataque, se deben proteger físicamente los equipos con instalaciones seguras y controles de acceso. Además, se deben configurar los equipos cerrando puertos innecesarios, deshabilitando protocolos de comunicación no pertinentes y desplegando medidas como firewalls y sistemas de detección de intrusos en el entorno de red. Es esencial mantener el firmware actualizado y evitar que personal no autorizado manipule la configuración de los equipos.

Recursos Humanos: Por último, los recursos humanos representan una superficie de ataque crucial, ya que las personas pueden actuar contra los intereses de la organización por diversas razones. Además de implementar protocolos de actuación, es recomendable establecer sistemas de registro y auditoría para rastrear las actividades de los usuarios. Esto ayuda a minimizar la probabilidad de éxito de amenazas humanas al evitar el anonimato. También es importante invertir en educación y concienciación para que los usuarios comprendan la importancia de mantener un alto nivel de seguridad en los recursos e infraestructuras de la organización.

ACTIVIDAD 1

Le pedimos que realice la Actividad que le proponemos en el campus de manera de ir afianzando conceptos vistos hasta aquí.

ACTIVIDAD 2 (Tarea)

Le pedimos que realice la Actividad que le proponemos en el campus y la envíe al tutor para su corrección.

ACTIVIDAD 3 (Foro)

Le pedimos que a continuación participe del Foro que le proponemos e intercambie reflexiones con sus compañeros.

Antes de continuar con la lectura de la unidad 2 y para poner en práctica los conceptos y procedimientos aprendidos en la presente unidad, le invitamos a realizar la autoevaluación integradora de la unidad 1

SÍNTESIS DE LA UNIDAD

La Unidad I aborda los conceptos fundamentales relacionados con la seguridad informática, centrándose en los términos "Recursos", "Amenazas", "Vulnerabilidades" y "Riesgos". Los recursos se refieren a los bienes tangibles e intangibles utilizados para llevar a cabo las tareas, como la información y los recursos físicos de la empresa. Los riesgos son la probabilidad de que ocurra algo negativo que dañe los recursos, mientras que las amenazas son sucesos que pueden causar daño, y las vulnerabilidades son fallos en los sistemas de seguridad que podrían ser aprovechados por las amenazas.

También menciona la importancia de evaluar los riesgos identificando las vulnerabilidades y amenazas, y cómo esto se puede hacer mediante una tabla de evaluación de riesgos. Se discuten diferentes tipos de amenazas, tanto naturales como voluntarias, y se aborda la importancia de minimizar las vulnerabilidades a través de medidas preventivas, correctivas y detectivas.

Además, se exploran los conceptos de seguridad en términos generales, seguridad informática y seguridad de la información, destacando la importancia de proteger los datos y sistemas de información de una organización. Se discuten los pilares de la seguridad de la información: integridad, disponibilidad y confidencialidad, así como el principio de mínimos privilegios y la importancia de reducir la superficie de ataque.

Finalmente, se aborda el papel de la infraestructura TI, software, hardware y recursos humanos como una superficie de ataque, destacando la importancia de implementar protocolos de seguridad, sistemas de registro y auditoría, y la educación y concienciación de los usuarios para mantener un alto nivel de seguridad.

Si Ud. ha realizado las Actividades propuestas con éxito, ha logrado los objetivos:

- Reconocer y clasificar amenazas, vulnerabilidades y ataques en entornos digitales.
- Comprender los principios básicos de seguridad informática y sus componentes.
- Analizar y aplicar los pilares fundamentales de seguridad informática en la protección de sistemas y datos.

Podrá continuar con la Unidad 2

¡¡¡¡FELICITACIONES!!!!